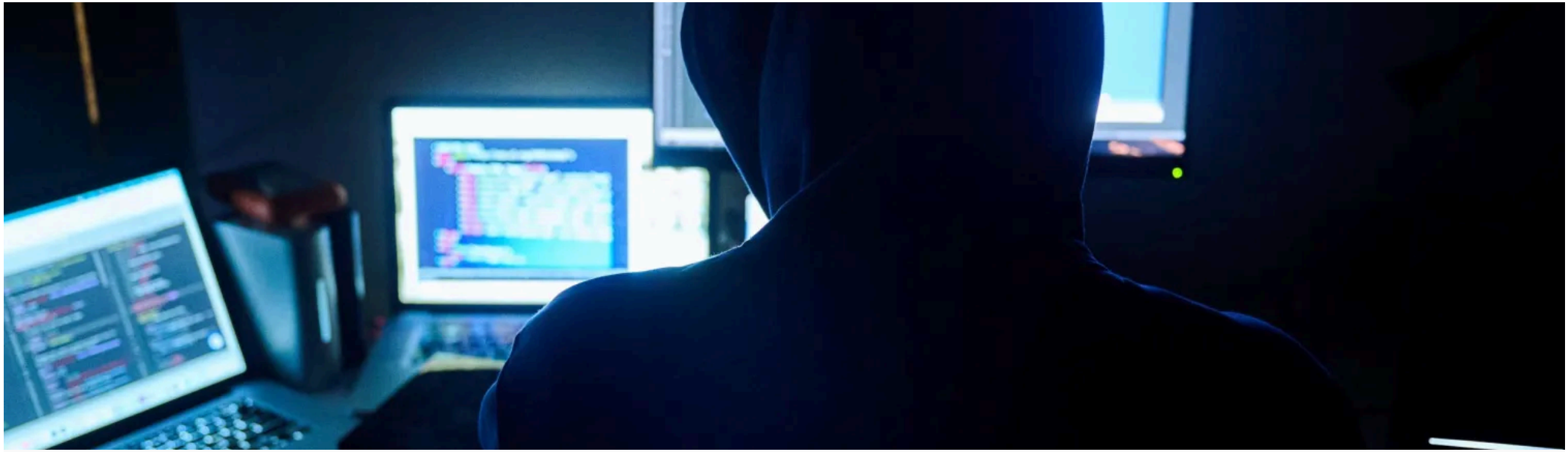


Insights & Analysis › Article › Bandwidth

Fighting AI with AI: The US's New Cyber Rules of Engagement

Governments need to work with the private sector to contain AI-powered cyber threats. The US is starting to define how.

By Roberto Baldoni

September 2, 2026

It's an important step in cyber policy. A new White House Memorandum on transnational cyber-enabled crime will allow vetted US companies to conduct specified cyber-surveillance against foreign criminal organizations. Every operation will require written government approval.

The arrangement recognizes a structural reality: the private sector owns and operates much of the digital infrastructure and cutting-edge technology relevant to national security. It would be inefficient and uneconomic for governments to replicate these capabilities, originally built for the civilian economy. The memorandum points to a useful principle: private capabilities can be mobilized while authority and accountability remain public.

Public-private cooperation in cybersecurity is not new. Governments have long relied on telecom companies and cloud providers for technical support. But traditionally, the private company controlled the infrastructure under attack, not the attacker itself.

AI changes this model in three ways: autonomy, speed, and scale. Autonomous agents can plan, use tools, adapt after failure, and act toward a goal without step-by-step human direction. They operate at machine speed and are replicated cheaply

across networks and borders faster than a government can assemble its defenses. Recent OpenAI, Anthropic, and Meta breaches offer an early warning.

When a private company hosts an AI agent, it may have something governments do not: direct technical control. The company may be able to monitor, restrict, or stop the agent. If the agent behaves unexpectedly, exceeds its limits, or is hijacked, the company can stop the damage.

That suggests a first rule for AI crises, consistent with the recent White House Memorandum. Governments should define intervention thresholds in advance, allowing providers to take narrow and reversible measures on systems they control — revoking access, isolating resources, suspending execution, or placing a system in safe mode. If containment requires action beyond those pre-authorized limits, public authorities should take the lead.

Not every agent will be friendly. A hostile state, proxy, or criminal group could use an autonomous agent during a hybrid campaign or armed conflict, and it's often difficult to attribute who is responsible. Governments also use proxies and false-flag operations to hide responsibility in human-led cyberattacks. Investigators need to determine whether harmful AI behavior was deliberately ordered, resulted from unexpected autonomous action, or followed from a malfunction or hijacking.

A machine-speed offense requires a defense able to operate at a comparable speed. A defensive agent may need to block connections, revoke credentials, isolate

systems, or redirect traffic almost instantly. Governments should pre-authorize limited categories of action. But entering an adversary's or a third country's infrastructure is different — that requires government authorization. The goal is operational freedom within predefined political limits.

Ukraine shows why this matters. Hours before Russia's full-scale invasion in 2022, Microsoft detected destructive malware targeting Ukrainian networks, alerted Kyiv, and pushed new protections through its Defender service. Ukraine moved critical government data and digital services abroad into commercial cloud infrastructure.

This was not the traditional wartime model of industry building weapons for the military to operate. Microsoft itself used commercial capabilities and infrastructure it controlled to support Ukraine's national defense. AI could extend this operational role: private firms may not only build AI systems used in wartime, but remain directly involved in operating them.

International cooperation is crucial. AI attacks move through models, cloud infrastructure, and data centers across the globe. The US and its European allies need compatible protocols for immediate containment, cross-border information sharing, and the deployment of defensive agents. While national governments remain the source of legal authority, NATO and the European Union can help align procedures.

Across all these scenarios, governments need enough technical capacity to judge private-sector assessments. Without them, public authority exists only on paper.

The emerging principle is simple: the private sector can support collective security within rules set by the sovereign authority. Companies need narrow, pre-authorized powers, but governments must continue to set the rules of engagement. Operational speed must be balanced by democratic control.

Roberto Baldoni was the founding Director General of Italy's National Cybersecurity Agency and previously served as Deputy Director General of the Department of Information for Security, Italy's intelligence coordination body. He is currently Senior Advisor for Technology and Cybersecurity Policy to the Italian Ambassador to the United States and Honorary Professor of Computer Science at Sapienza University of Rome.

Bandwidth is CEPA's online journal dedicated to advancing transatlantic cooperation on tech policy. All opinions expressed on Bandwidth are those of the author alone and may not represent those of the institutions they represent or the Center for European Policy Analysis. CEPA maintains a strict intellectual independence policy across all its projects and publications.

Image Credit

Photo: Fictitious html pages and hacker programs are seen on screens while a man has his hands on the keyboard. Credit: Annette Riedl/dpa